



杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

网络空间安全学院

网络安全协议分析

吕秋云

laqyzj@hdu.edu.cn





原有通信协议 (TCP/IP 家族) 存在以下安全问题:

源端鉴别问题;

数据传输的保密性问题;

数据传输的完整性问题;

身份鉴别问题。





- 一、安全协议总览
- 二、TLS协议分析
- 三、IPSEC协议分析
- 四、TLS 与 IPSec 比较





杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

提 纲

一、安全协议总览





一、安全协议总览

Q1: 安全?

Q2: 协议?

目标?

安全目标

机密性

完整性

可用性

A1: 广义: security + safty

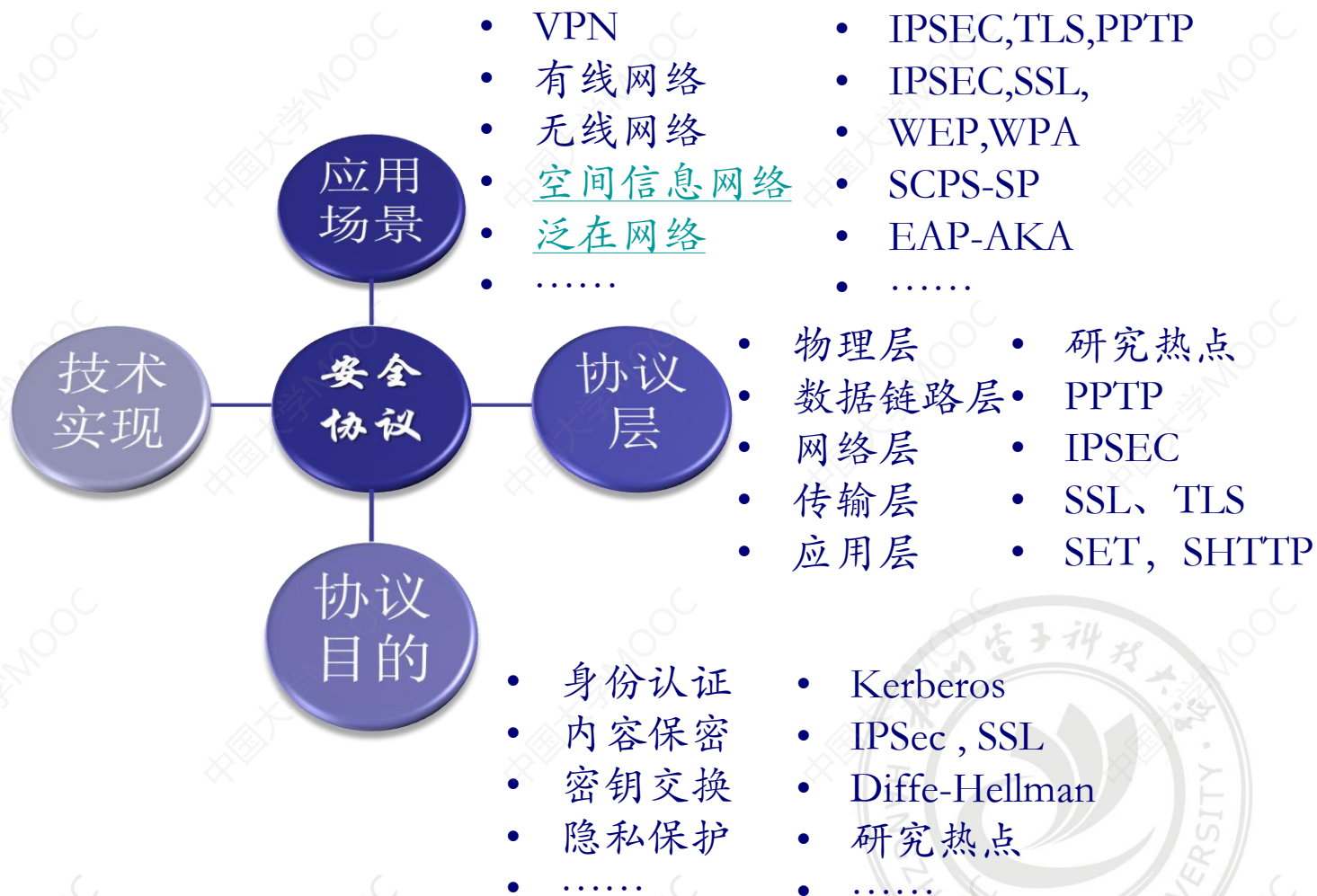
狭义: security

A2: 双方的约定





一、安全协议总览





一、安全协议总览

TLS/SSL



IPSEC

PPTP



杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

提 纲

二、TLS协议分析

(TLS1.0=SSL3.0)





2.1 TLS协议体系结构

TLS握手 协议	TLS密钥 交换协议	TLS报警 协议	HTTP	FTP
TLS记录协议				
传输控制协议（TCP）				
网间协议（IP）				

➡ TLS记录协议位于传输层与应用层之间；

➡ TLS握手协议、TLS密钥交换协议和TLS报警协议均与HTTP和FTP一样属于应用层协议。



TLS记录协议

发送时:

- ➡ 1. 将数据分片成可管理的块,
- ➡ 2. 进行数据压缩(可选),
- ➡ 3. 应用MAC,
- ➡ 4. 利用IDEA、DES、3DES或其他加密算法进行数据加密
- ➡ 5. 增加由内容类型、主要版本、次要版本和压缩长度组成的首部。

消息完整性

机密性

接收时:

- ➡ 接收的数据刚好与接收数据工作过程相反,依次被解密、验证、解压缩和重新装配,然后交给更高级用户。



TLS密钥交换协议是负责更新用于当前连接的密码组。为了保障TLS传输过程的安全性,双方应该每隔一段时间改变加密规范。

TLS告警协议是用来为对等实体传递TLS的相关警告。如果在通信过程中某一方发现任何异常,就需要给对方发送一条警示消息通告。

警示消息有两种:一种是 **Fatal** 错误,如传递数据过程中,发现错误的MAC,双方就需要立即中断会话,同时消除自己缓冲区相应的会话记录;

第二种是 **Warning** 消息,这种情况,通信双方通常都只是记录日志,而对通信过程不造成任何影响。



TLS握手协议可以使得**服务器和客户**能够**相互鉴别对方**,协商具体的**加密算法**和**MAC算法**以及**保密密钥**,用来保护在TLS记录中发送的数据。

TLS握手协议是在任何应用程序数据传输之前**使用**的。TLS握手协议包含**四个阶段**:

- 第一个阶段建立安全能力;
- 第二个阶段服务器鉴别和密钥交换;
- 第三个阶段客户鉴别和密钥交换;
- 第四个阶段完成握手协议。



二、TLS协议分析

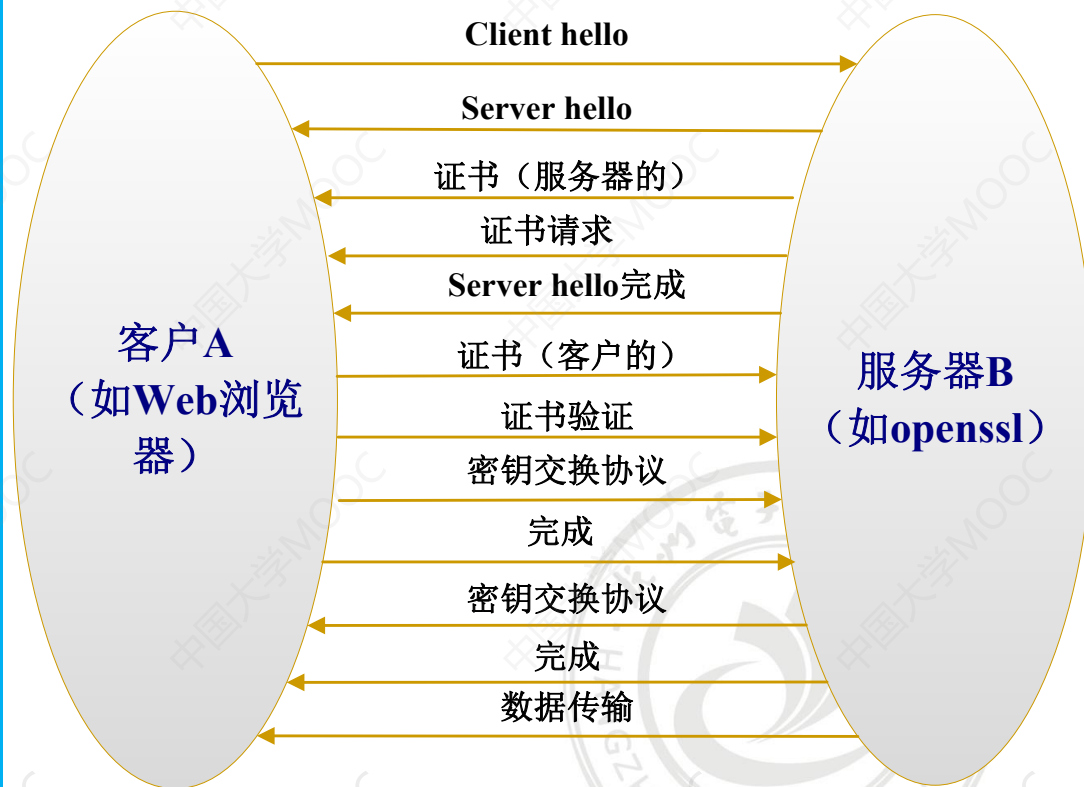
与许多C/S方式一样:

- ➡客户端向服务器发送“Client hello”信息打开连接;
- ➡服务器用“Server hello”回答;
- ➡要求客户端提供它的数字证书;
- ➡完成证书验证, 执行密钥交换协议

密钥交换协议的任务:

- ➡产生一个密钥;
- ➡由主密钥产生两个会话密钥:
A→B的密钥和B→A的密钥;
- ➡由主密钥产生两个消息认证码密钥

2.2.TLS协议的连接建立过程





上述为TLS握手协议理论描述实现的4个阶段，
那么在真实的抓包数据中你能否找到四个阶段——
一一对应的数据内容吗？

真实的抓包样例如下：





二、TLS协议分析

2.2.TLS协议的连接建立过程

Source	Destination	Protocol	Length	Info
192.168.1.102	218.205.84.250	TLSv1.2	260	Client Hello ①
218.205.84.250	192.168.1.102	TLSv1.2	1494	Server Hello ②
218.205.84.250	192.168.1.102	TLSv1.2	1003	CertificateServer Key Exchange, Server Hello Done ③
192.168.1.102	218.205.84.250	TLSv1.2	180	Client Key Exchange, Change Cipher Spec, Hello Request, Hello Request ④
218.205.84.250	192.168.1.102	TLSv1.2	296	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message ⑤
192.168.1.102	218.205.84.250	TLSv1.2	934	Application Data
218.205.84.250	192.168.1.102	TLSv1.2	1483	Application Data



Secure Sockets Layer

TLSv1.2 Record Layer: Handshake Protocol: Client Hello

Content Type: Handshake (22)

Version: TLS 1.0 (0x0301)

Length: 201

Handshake Protocol: Client Hello

Handshake Type: Client Hello (1)

Length: 197

Version: TLS 1.2 (0x0303)

Random

Session ID Length: 0

Cipher Suites Length: 32

Cipher Suites (16 suites)

Cipher Suite: Unknown (0x3a3a)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc030)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc034)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca9)

Cipher Suite: TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcc08)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcc14)

Cipher Suite: TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcc13)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)

Cipher Suite: TLS_RSA_WITH_AES_128_GCM_SHA256 (0x009c)

Cipher Suite: TLS_RSA_WITH_AES_256_GCM_SHA384 (0x009d)

Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA (0x002f)

Cipher Suite: TLS_RSA_WITH_AES_256_CBC_SHA (0x0035)

Cipher Suite: TLS_RSA_WITH_3DES_EDE_CBC_SHA (0x000a)

Compression Methods Length: 1

Compression Methods Length: 1

Compression Methods (1 method)

Extensions Length: 124

Extension: Unknown 31354

Extension: renegotiation_info

Extension: server_name

Extension: Extended Master Secret

Extension: SessionTicket TLS

Extension: signature_algorithms

Extension: status_request

Extension: signed_certificate_timestamp

Extension: Application Layer Protocol Negotiation

Extension: channel_id

Extension: ec_point_formats

Extension: elliptic_curves

Extension: Unknown 43690

①

Client hello



- ▼ Secure Sockets Layer
 - ▼ TLSv1.2 Record Layer: Handshake Protocol: Server Hello
 - Content Type: Handshake (22)
 - Version: TLS 1.2 (0x0303)
 - Length: 80
 - ▼ Handshake Protocol: Server Hello
 - Handshake Type: Server Hello (2)
 - Length: 76
 - Version: TLS 1.2 (0x0303)
 - Random
 - Session ID Length: 0
 - Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)
 - Compression Method: null (0)
 - Extensions Length: 36
 - Extension: server_name
 - Extension: renegotiation_info
 - Extension: ec_point_formats
 - Extension: SessionTicket TLS
 - Extension: Application Layer Protocol Negotiation

②

Server Hello





- ▼ Secure Sockets Layer
 - ▼ TLSv1.2 Record Layer: Handshake Protocol: Certificate
 - Content Type: Handshake (22)
 - Version: TLS 1.2 (0x0303)
 - Length: 3392
 - ▼ Handshake Protocol: Certificate
 - Handshake Type: Certificate (11)
 - Length: 3388
 - Certificates Length: 3385
 - › Certificates (3385 bytes)
 - ▼ Secure Sockets Layer
 - ▼ TLSv1.2 Record Layer: Handshake Protocol: Server Key Exchange
 - Content Type: Handshake (22)
 - Version: TLS 1.2 (0x0303)
 - Length: 333
 - ▼ Handshake Protocol: Server Key Exchange
 - Handshake Type: Server Key Exchange (12)
 - Length: 329
 - › EC Diffie-Hellman Server Params
 - › TLSv1.2 Record Layer: Handshake Protocol: Server Hello Done

⑧
**certificate,
Server key Exchange,
Hello Done**



✓ Secure Sockets Layer

✓ TLSv1.2 Record Layer: Handshake Protocol: Client Key Exchange

Content Type: Handshake (22)

Version: TLS 1.2 (0x0303)

Length: 70

‣ Handshake Protocol: Client Key Exchange

✓ TLSv1.2 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec

Content Type: Change Cipher Spec (20)

Version: TLS 1.2 (0x0303)

Length: 1

Change Cipher Spec Message

✓ TLSv1.2 Record Layer: Handshake Protocol: Multiple Handshake Messages

Content Type: Handshake (22)

Version: TLS 1.2 (0x0303)

Length: 40

✓ Handshake Protocol: Hello Request

Handshake Type: Hello Request (0)

Length: 0

✓ Handshake Protocol: Hello Request

Handshake Type: Hello Request (0)

Length: 0

④

**Client key Exchange,
Change Cipher spec
Handshake Messages**



Secure Sockets Layer

TLSv1.2 Record Layer: Handshake Protocol: New Session Ticket

Content Type: Handshake (22)

Version: TLS 1.2 (0x0303)

Length: 186

Handshake Protocol: New Session Ticket

TLSv1.2 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec

Content Type: Change Cipher Spec (20)

Version: TLS 1.2 (0x0303)

Length: 1

Change Cipher Spec Message

TLSv1.2 Record Layer: Handshake Protocol: Encrypted Handshake Message

Content Type: Handshake (22)

Version: TLS 1.2 (0x0303)

Length: 40

Handshake Protocol: Encrypted Handshake Message

⑤
New session Ticket
Change cipher spec
Encrypted Handshake Message



根据TLS握手协议理论描述和现实抓包数据对比
，你发现了什么？





数据加密



• **数据完整性检测**



双向身份鉴别



防重放攻击机制





杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

提 纲

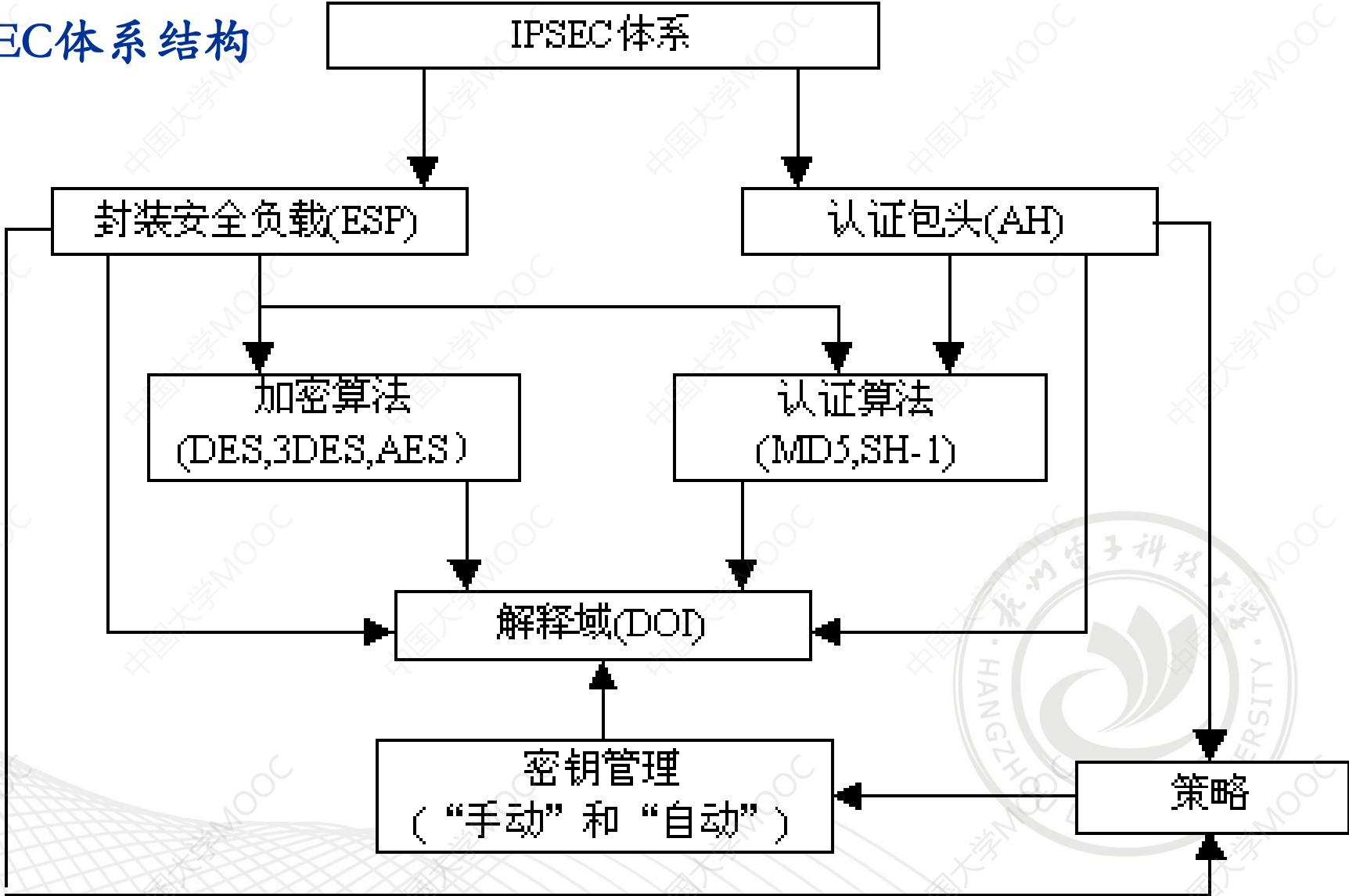
三、IPSEC协议分析





三、IPSEC协议分析

IPSEC体系结构





3.1 IPSec的工作原理

1

➡ IPSec的工作原理类似于包过滤防火墙，可以把它看做是包过滤防火墙的一种扩展。

2

➡ IPSec网关通过查询安全策略数据库（SPD）决定对接收到的IP数据包进行转发、丢弃或IPSec处理。

3

➡ IPSec网关可以对IP数据包只进行加密或认证，也可以对数据包同时实施加密和认证。



无论是进行加密还是进行认证，IPSec都有两种工作模式：传输模式和隧道模式。



- ➡ IPSec协议使用**认证头标AH**和**封装安全净载ESP**两种安全协议来提供安全通信。
- ➡ 两种安全协议都分为**隧道模式**和**传输模式**。
- ➡ **传输模式**用在主机到主机的通信，
- ➡ **隧道模式**用在其它任何方式的通信。

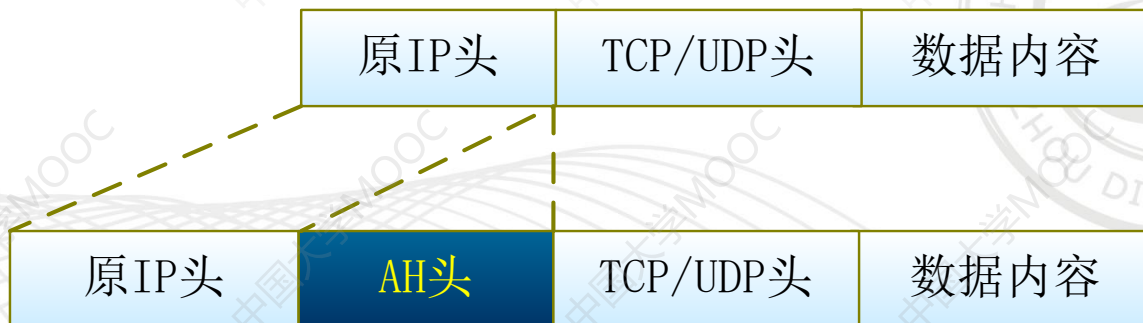


- 采用传输模式时，IPSec对IP数据包的净荷进行加密或认证。
- 封装数据包继续使用原IP头部，只对部分域进行修改。
- 而IPSec协议头部插入到原IP头部和传输层头部之间。

传输模式的ESP封装示意图



传输模式的AH封装示意图

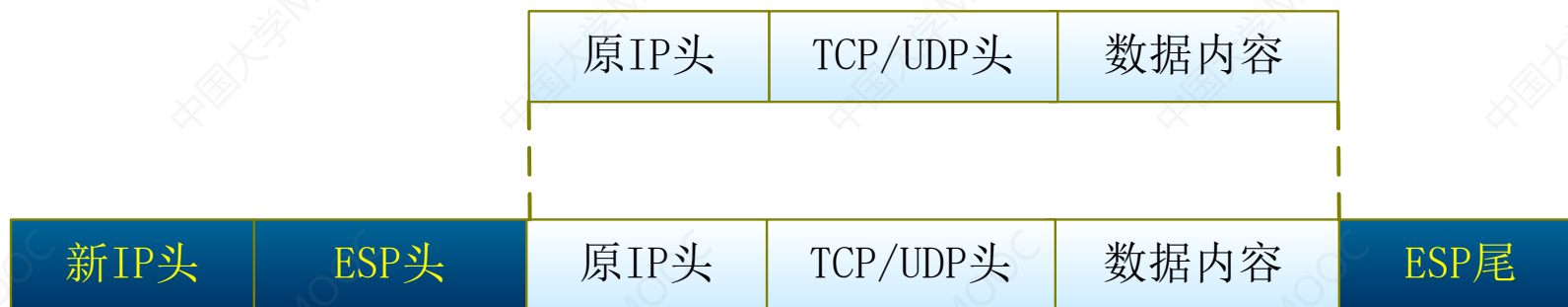




3.1 IPSec的工作原理

- 采用隧道模式时，IPSec对整个IP数据包进行加密或认证。
- 产生一个新的IP头，IPSec头被放在新IP头和原IP数据包之间，组成一新IP头。

IPSec隧道模式的ESP封装示意图



IPSec隧道模式的AH封装示意图





3.1 IPSec的工作原理

版本 (4位)	头长度 (4位)	服务类型 (8位)	封包总长度 (16位)	
封包标识 (16位)			标志 (3位)	片断偏移地址 (13位)
存活时间 (8位)		协议 (8位)	校验和 (16位)	
来源IP地址 (32位)				
目的IP地址 (32位)				
选项 (可选)			填充 (可选)	
数据				

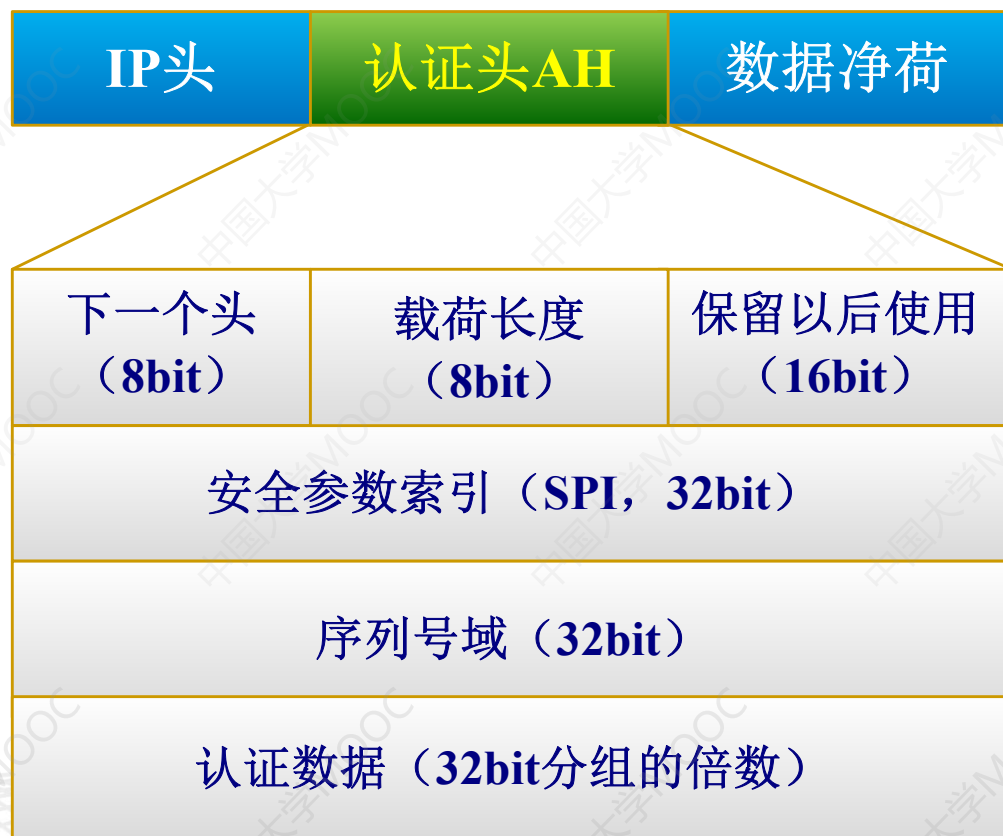


IPSec的功能和模式

功能/模式	认证头协议 (AH)	封装安全载荷 (ESP)	ESP+AH
访问控制	Yes	Yes	Yes
认证	Yes	—	Yes
消息完整性	Yes	—	Yes
重放保护	Yes	Yes	Yes
机密性	—	Yes	Yes



认证头（AH）的结构及其在IP数据包中的位置





传输模式AH认证协议发送方：

- ➡ 创建一个外出SA(手工或通过IKE)
- ➡ 产生序列号
- ➡ 填充AH头的各字段
- ➡ 计算ICV (Intergrity Check Value) : IP头非可变域, AH自身, 上层协议数据
- ➡ AH头的下一头为原IP报头协议字段值, 原IP报头的协议字段为51.



传输模式AH认证协议接收方：

- ➡ 分片装配
- ➡ 查找SA （根据目标IP， AH， SPI）
- ➡ 检查序列号
- ➡ 验证ICV





2 ESP (Encapsulating Security Payload)

ESP协议主要用于对IP数据包进行加密，此外也对认证提供某种程度的支持。

ESP协议也有两种工作模式：**传输模式**和**隧道模式**。

安全参数索引 (SPI 32bit)			
序列号域 (32bit)			
载荷数据 (32bit分组的倍数)			
填充数据 (0~255byte)			
		填充长度 (8bit)	下一个头 (8bit)
认证数据 (32bit分组的倍数)			



传输模式ESP协议发送方：

- ➡ 创建一个外出SA(手工或通过IKE)
- ➡ 加密封装必要的的数据放在payload中
- ➡ 增加padding数据
- ➡ 计算ICV（加密后的）
- ➡ ESP的下一个头为原IP报头协议字段值，原IP报头的协议字段为50.



传输模式ESP协议接收方：

- ➔ 分片装配
- ➔ 查找SA（根据目标IP，ESP，SPI）
- ➔ 检查序列号
- ➔ 验证ICV
- ➔ 解密：根据SA中指定的算法和密钥，进行解密；去掉padding，重组IP包



3 IKE (Internet Key Exchange)

IKE用于动态建立安全关联 (SA, Security Association)

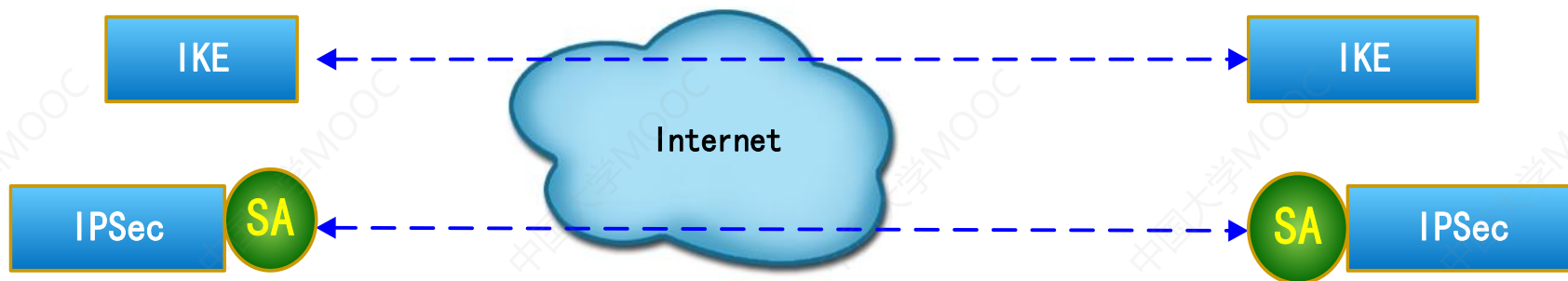
IKE协议分两个阶段:

- ➡ 第一阶段: 建立IKE安全关联, 即在通信双方之间协商密钥
- 第二阶段: 利用这个既定的安全关联建立IPSec安全关联



3.2 IPSec的主要协议

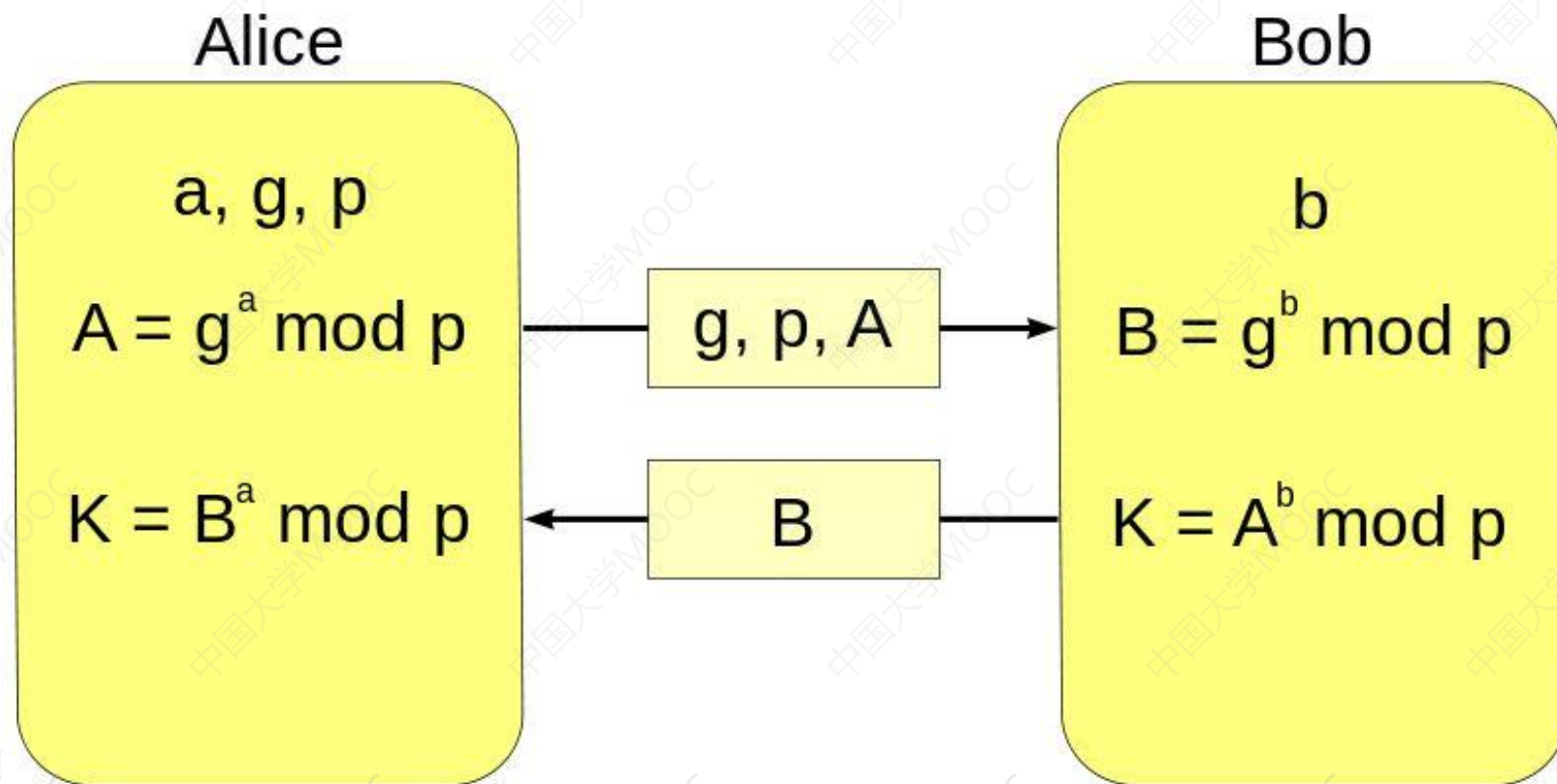
(a) IKE建立SA



(b) IPSec可以建立安全通道



Diffie-Hellman密钥交换算法



$$K = A^b \bmod p = (g^a \bmod p)^b \bmod p = g^{ab} \bmod p = (g^b \bmod p)^a \bmod p = B^a \bmod p$$



ISAKMP通过IKE对以下密钥机制提供支持：

- ➡ 预共享密钥 (PSK)
- ➡ 公钥基础设施 (PKI)
- ➡ IPSec实体身份的第三方证书

IKE 既是IPSec协议实现的核心，又可能成为系统的瓶颈

进一步优化IKE程序和密码算法是实现IPSec的核心问题之一。



- ▶ IPsec的中心概念之一是“安全关联” - Security Association
- ▶ **由于SA是单向的，在一对对等系统间进行双向安全通信时，就需要两个SA：SA(out) SA(in)**
- ▶ 每个SA的标识由三部分组成：

1.

安全性参数索引，即SPI

2.

IP目的(源)地址

3.

安全协议标识，即AH或ESP





- ➡ **SA与协议相关**，一个SA 为业务流仅提供一种安全机制(AH或ESP)，即每种协议都有一个SA：SA(AH) SA(ESP)
- ➡ **SA可以通过静态配置来建立，也可以利用密钥管理协议(IKE)来动态建立**
- ➡ **SA包括众多参数，存储在安全关联数据库，由SPI唯一的标出**

1.

认证和加密的算法

2.

认证和加密的密钥

3.

生存周期等其他信息





认证和加密算法

(a) Virtual private networks (RFC 4308)

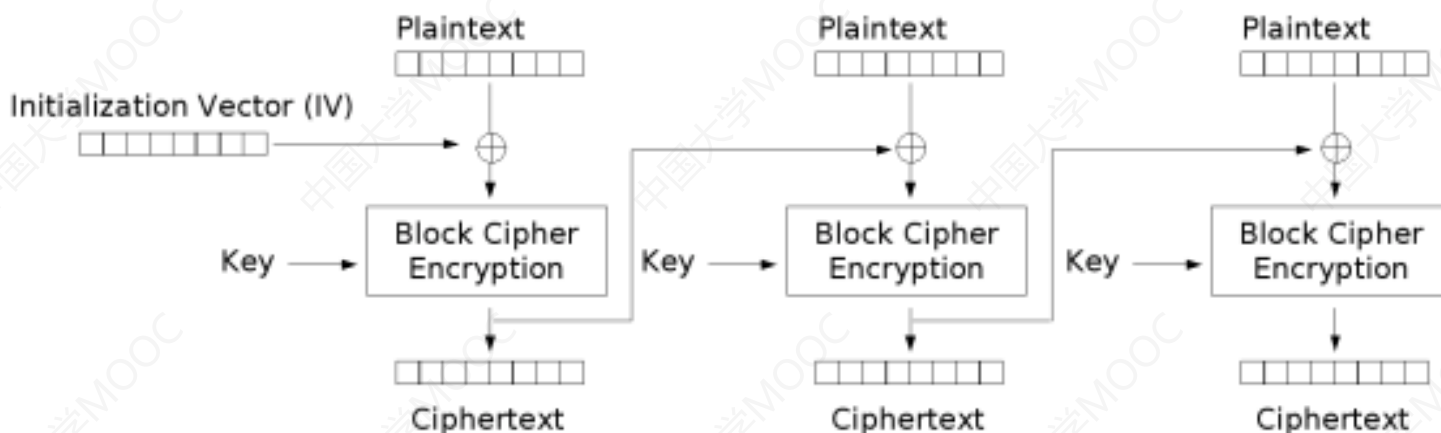
	VPN-A	VPN-B
ESP encryption	3DES-CBC	AES-CBC (128-bit key)
ESP integrity	HMAC-SHA1-96	AES-XCBC-MAC-96
IKE encryption	3DES-CBC	AES-CBC (128-bit key)
IKE PRF	HMAC-SHA1	AES-XCBC-PRF-128
IKE Integrity	HMAC-SHA1-96	AES-XCBC-MAC-96
IKE DH group	1024-bit MODP	2048-bit MODP

(b) NSA Suite B (RFC 4869)

	GCM-128	GCM-256	GMAC-128	GMAC-256
ESP encryption/ Integrity	AES-GCM (128-bit key)	AES-GCM (256-bit key)	Null	Null
ESP integrity	Null	Null	AES-GMAC (128-bit key)	AES-GMAC (256-bit key)
IKE encryption	AES-CBC (128-bit key)	AES-CBC (256-bit key)	AES-CBC (128-bit key)	AES-CBC (256-bit key)
IKE PRF	HMAC-SHA- 256	HMAC-SHA- 384	HMAC-SHA- 256	HMAC-SHA- 384
IKE Integrity	HMAC-SHA- 256-128	HMAC-SHA- 384-192	HMAC-SHA- 256-128	HMAC-SHA- 384-192
IKE DH group	256-bit random ECP	384-bit random ECP	256-bit random ECP	384-bit random ECP

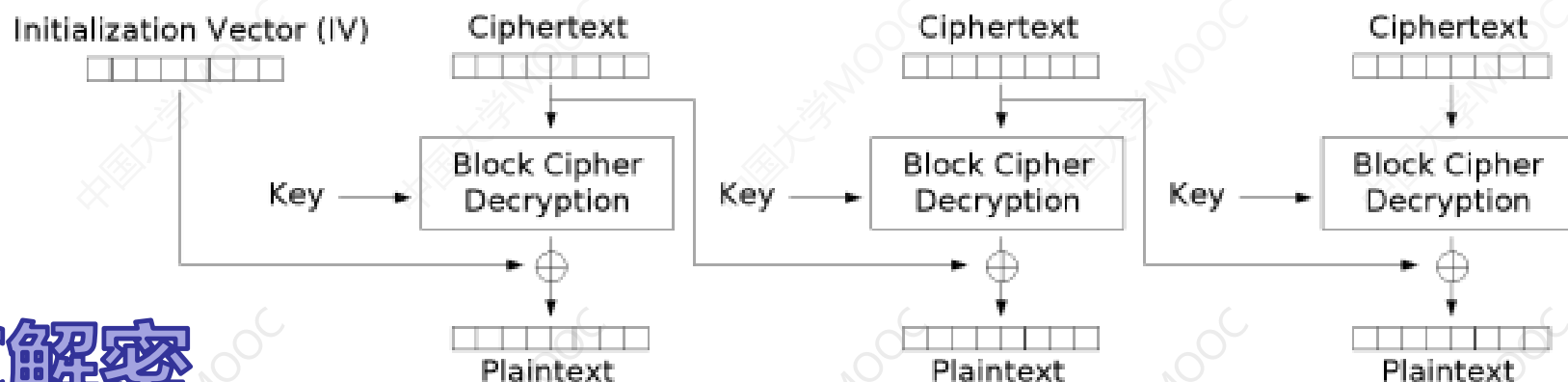


CBC加密



Cipher Block Chaining (CBC) mode encryption

CBC解密

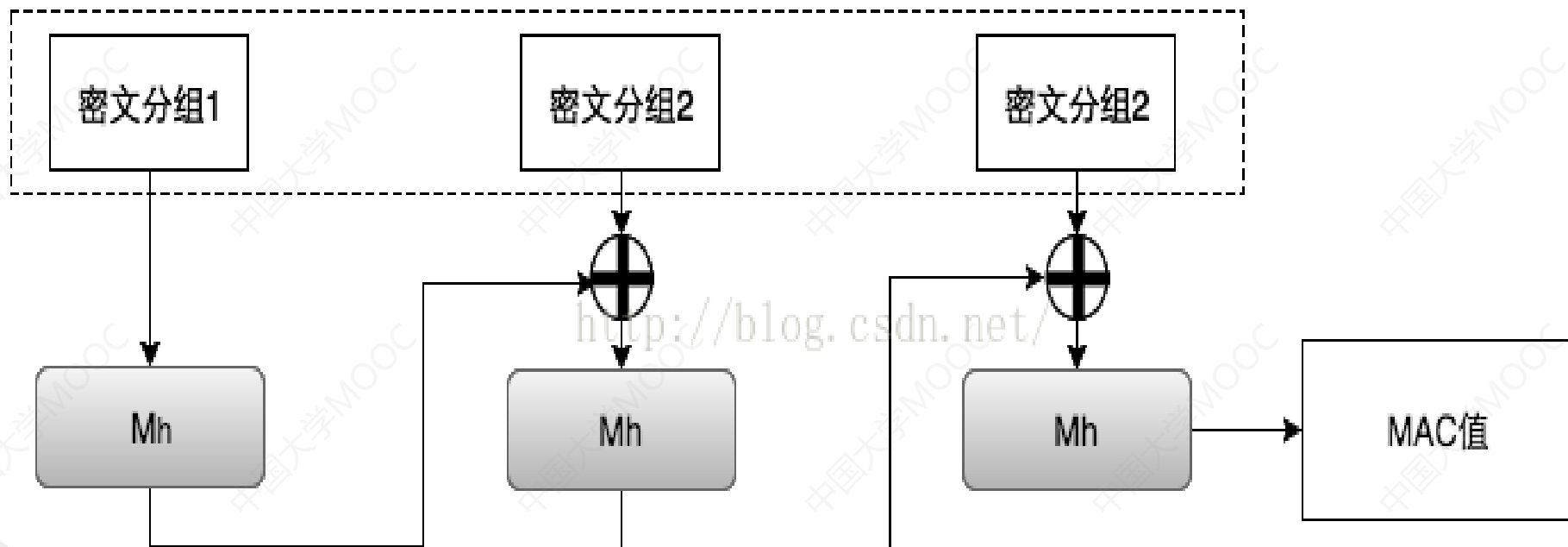


Cipher Block Chaining (CBC) mode decryption



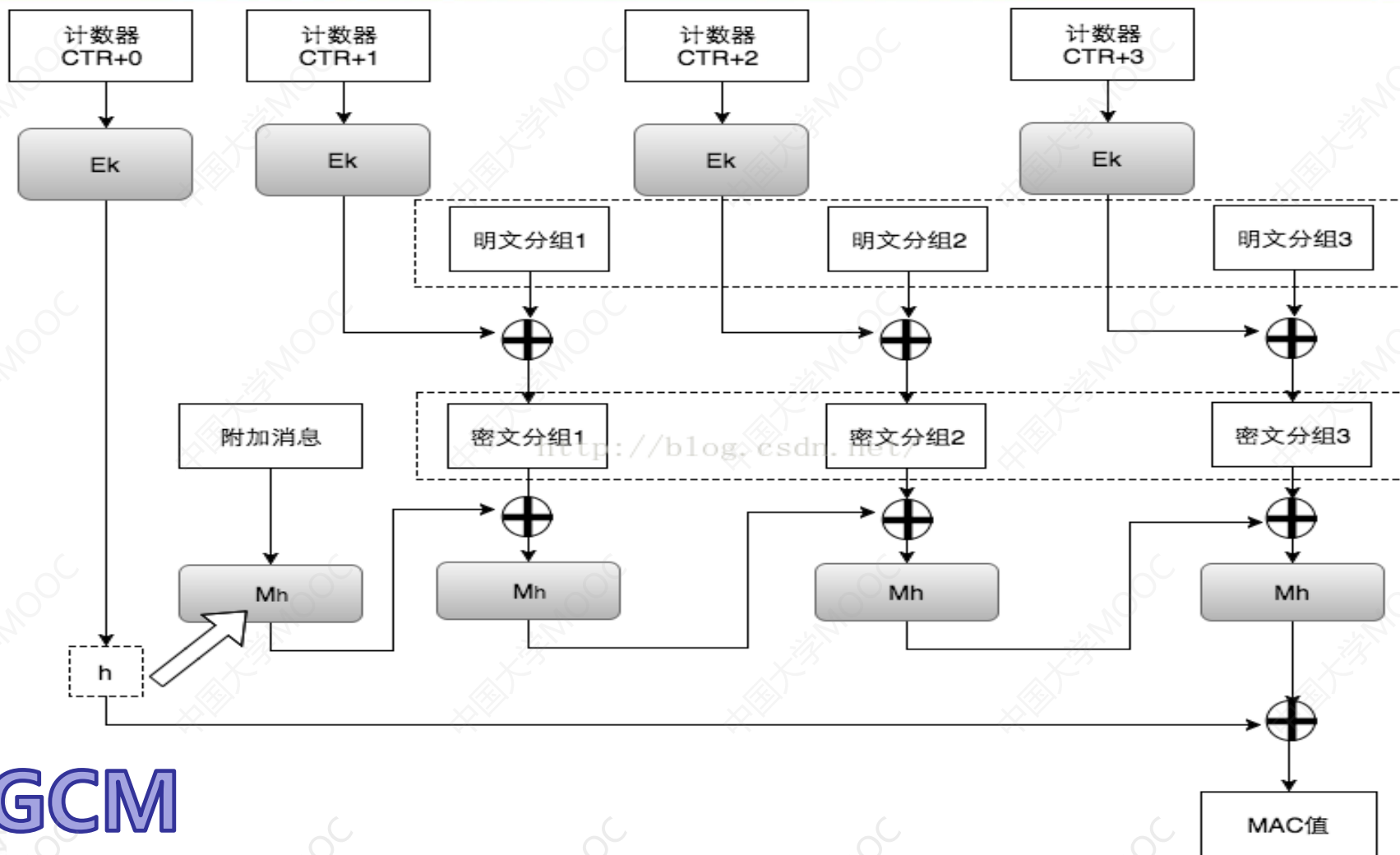
GMAC

Galois message authentication code mode





3.3 安全关联-SA



GCM

Galois/Counter Mode



杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

提 纲

四、TLS 与 IPSec 比较





四、TLS 与 IPsec 比较

选项	TLS	IPSec
身份验证	单向身份验证, 双向身份验证 数字证书	双向身份验证 数字证书
加密	强加密, 基于Web浏览器	强加密, 依靠执行
全程安全性	端到端安全 从客户到资源端全程加密	网络边缘到客户端 仅对从客户到网关之间通道加密
可访问性	适用于任何时间、任何地点访问	限制适用于已经定义好受控用户的访问
费用	低 (无须任何附加客户端软件)	高 (需要管理客户端软件)
安装	即插即用安装 无须任何附加的客户端软、硬件安装	通常需要长时间的配置 需要客户端软件或硬件
用户的易使用性	对用户非常友好, Web浏览器 无须终端用户的培训	对没有相应技术的用户比较困难 需要培训
支持的应用	基于Web的应用, 文件共享, E-mail	所有基于IP协议的服务
用户	客户、合作伙伴用户、远程用户、供应商等	更适合在企业内部使用



杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

谢谢!

